

Концепція прав доступу — MCP Gateway

Огляд

Система управління правами доступу побудована на двох незалежних рівнях.

Platform Permissions визначають, що користувач може робити в адміністративному інтерфейсі: керувати з'єднаннями (connections), користувачами, робочими просторами (workspaces), переглядати журнал аудиту тощо. Доступ контролюється каталогом із 32 дозволів, об'єднаних у 8 системних та довільну кількість користувацьких ролей.

Data Permissions визначають, до яких джерел даних та з якими SQL-операціями користувач може звертатися через MCP-проксі. Доступ надається через членство в робочому просторі (WorkspaceUser) або через прямий грант (UserDataSourceAccess). Усередині кожного джерела можна обмежити доступ до списку дозволених таблиць (allowedTables) або застосувати постійний блок-список на рівні з'єднання (blockedTables).

Користувача можна тимчасово деактивувати без видалення (User.suspendedAt) — це негайно блокує вхід в адміністративний інтерфейс та використання MCP-ендпоінту. Усі ролі та грантовані права при цьому зберігаються.

Ідентифікація користувачів

- Адмін-інтерфейс — внутрішня credentials-аутентифікація через Auth.js v5 (email + bcrypt-хеш пароля), JWT-сесія, що містить лише user.id.
- MCP-клієнти — OAuth 2.1 PKCE через вбудований OIDC-провайдер (oidc-provider); упаковані access-токени з валідацією через DB, TTL 1 година, ротовані refresh-токени.

Роль owner має повний набір 32 дозволів і захищена від видалення/перевизначення через спеціальні інваріанти на боці серверних маршрутів (видалення Owner-користувача та призначення Owner-ролі залишаються Owner-only).

Примітка: цей документ описує реалізацію станом на поточний момент. UI ілюструється посиланнями на конкретні файли в репозиторії; скріншоти не додаються — фронтенд продовжує змінюватися.

Список користувачів

Список усіх користувачів доступний за пунктом меню Users (/users). Сторінка показує:

- Аватар та ім'я
- Email
- Основну системну роль (badge біля імені) та +N чіп, якщо у користувача декілька ролей (з тултіпом-переліком кожної)
- MCP Status — індикатор того, чи має користувач активний неперекритий OAuth-токен (доказ того, що MCP-клієнт під'єднаний)
- Kebab-меню «Quick actions» для зміни ролі, призупинення тощо

Доступні: сортування за колонками, пошук за іменем/email, фільтрація за роллю (включно з користувацькими), експорт у CSV, групові операції — bulk role assignment (системні ролі замінюють основну, користувацькі стекаються) та bulk delete.

Редагування користувача

Сторінка `/users/[id]` побудована як набір карток у двох колонках у сітці. Поточний порядок (зверху донизу):

Рядок 1 — Account / User Info

- Account: email, дата створення, прапорець `suspended`, MCP-URL з кнопкою копіювання. Owner-only: кнопки скидання пароля та призупинення.
- User Info: метрики за останній час — кількість запитів за 24 години / 7 днів, % помилок, `last active`, `last sign-in`, топ-5 викликаних tools.

Рядок 2 — Assigned Roles / Permission Overrides

- Assigned Roles: усі `UserRole`-присвоєння (глобальні та `workspace-scoped`) із джерелом гранту та датою; кнопки додати/видалити роль. Owner-роль призначається лише іншим Owner.
- Permission Overrides: усі `UserPermissionOverride`-рядки (GRANT або REVOKE окремого дозволу) з обов'язковим полем `reason` та опційним терміном дії `expiresAt`.

Рядок 3 — Workspaces / Connections

- Workspaces: список усіх `WorkspaceUser`-членств із бейджами рівнів доступу (View / Edit / Delete) і `hover`-кнопкою видалення.
- Connections: дедуплікований список усіх з'єднань, до яких користувач має доступ — через будь-яке членство в робочому просторі АБО прямий грант. Кожне джерело показує походження («via Engineering · Edit», «direct grant · View»).

Рядок 4 — Effective Permissions

Розгорнутий перелік усіх 32 дозволів каталогу з відмітками «має / не має» та поясненням джерела гранту (роль X / override / зі workspace Y). Картка займає всю ширину.

Platform Permissions

Платформенні права визначають, що користувач може робити в адміністративному інтерфейсі. Реалізовано через каталогічну RBAC-систему.

Каталог дозволів

Джерелом істини є файл `lib/permissions/catalog.ts`. Містить 32 дозволи, об'єднаних у 7 категорій:

Категорія	Приклади ключів
dashboard	<code>dashboard.view</code>
connections	<code>connections.view</code> , <code>.create</code> , <code>.update</code> , <code>.delete</code> , <code>.manage_credentials</code> , <code>.manage_tools</code>
users	<code>users.view</code> , <code>.create</code> , <code>.update</code> , <code>.change_role</code> , <code>.suspend</code> , <code>.delete</code> , <code>.reset_password</code>
workspaces	<code>workspaces.view</code> , <code>.create</code> , <code>.update</code> , <code>.delete</code> , <code>.manage_members</code> , <code>.manage_data_sources</code> , <code>.manage_data_permissions</code>
permissions	<code>permissions.view</code> , <code>.manage_roles</code> , <code>.manage_assignments</code> , <code>.manage_overrides</code>
audit	<code>audit.view_own</code> , <code>.view_all</code> , <code>.view_admin_events</code> , <code>.export</code>
settings	<code>settings.view</code> , <code>.manage_system</code>

Кожен дозвіл має прапорець `scopeable` — `true` означає, що грант можна обмежити конкретним робочим простором (більшість `workspaces.*` дозволів).

Системні ролі

Зашиті 8 ролей (`isSystem=true`) синхронізуються при кожному деплої через `tsx lib/permissions/seed.ts`:

Slug	Опис
owner	Усі 32 дозволи. Owner-only інваріанти: видалення Owner-користувача, призначення Owner-ролі.
admin	Усі 32 дозволи. Може створювати/редагувати/видаляти користувачів та користувацькі ролі. Не може видалити Owner або призначити Owner-роль.
editor	<code>dashboard</code> + повний <code>connections</code> + <code>audit.view_all</code> + <code>settings.view</code> . Менеджер з'єднань.
staff	<code>dashboard</code> + <code>workspaces.view</code> + <code>settings.view</code> . Тільки читання.
guest	<code>dashboard</code> + <code>connections.view</code> + <code>workspaces.view</code> + <code>settings.view</code> .
user	Порожній набір. Тільки MCP-клієнт, доступу до адмін-панелі немає. Дефолт для нових облікових записів.
workspace_admin	Workspace-scoped: керування членами, з'єднаннями та правами на дані. Призначається через ненульовий <code>UserRole.workspaceId</code> .
workspace_member	<code>dashboard</code> + <code>workspaces.view</code> + <code>settings.view</code> . Тільки для <code>scope</code> -присвоєнь.

Користувацькі ролі

Адміністратор з дозволом `permissions.manage_roles` може створювати власні ролі на сторінці `/permissions/roles`. Користувацькі ролі (`isSystem=false`) — це довільні комбінації дозволів каталогу. Системні ролі через UI не редагуються.

Per-User Overrides

На додачу до ролей кожному користувачу можна задати індивідуальний `UserPermissionOverride` — GRANT (додає окремий дозвіл) або REVOKE (відбирає дозвіл, який давала б роль). Обов'язкове поле `reason` (для аудиту), опційний `expiresAt`. Очищення прострочених override-ів виконує денний крон `/api/cron/expire-overrides`.

Перевірка дозволів

Усі API-маршрути та сторінки використовують helpers з `lib/auth.ts`:

- `requirePermission(key)` — повертає сесію або 401/403.
- `requirePermissionInWorkspace(key, workspaceId)` — те саме, але вимагає, щоб грант поширювався на конкретний робочий простір.
- `gatePermission(key)` — варіант для `server-component pages` (редірект замість JSON-відповіді).

Резолвер `lib/permissions/resolve.ts` обчислює ефективні права з `UserRole` + `RolePermission` + `UserPermissionOverride` і кешується через `React.cache()` на час одного запиту.

Data Permissions — Перегляд

Ефективний доступ користувача до даних обчислюється як об'єднання усіх джерел грантів:

```
Effective Access = (WorkspaceUser → WorkspaceDataSource) (UserDataSourceAccess)
```

Для кожного з'єднання обчислюються:

- **permissions** — об'єднання SQL-рівнів зі всіх джерел (відображається як View / Edit / Delete).
- **allowedTables** — об'єднання списків (якщо хоч одне джерело дає null — доступ до всіх таблиць).
- **sources** — мітковий список джерел гранту: адміністратор бачить, через який саме шлях користувач отримав доступ.

Картка Connections на сторінці користувача

Дедуплікований список з'єднань, доступних користувачу. Кожен рядок показує:

- Назву з'єднання та тип.
- Усі джерела гранту з провенансом («via Engineering · Edit», «direct grant · View»).

Permissions Matrix (/permissions)

Тристовкова сторінка:

- **By User** — лівий стовпчик зі списком користувачів, правий — список усіх з'єднань для вибраного користувача.
- **By Connection** — інверсний вид: лівий стовпчик з'єднань, правий — усі користувачі для вибраного з'єднання.
- **Matrix** — щільна таблиця «користувачі × з'єднання» з міні-бейджами V/E/D у кожній клітинці.

У всіх вкладках:

- **Direct-grant** клітинки помічаються іконкою Sparkles.
- **Workspace-походження** показується через bg-secondary бейджі («Sales · View · Edit»).
- Інлайн-індикатори таблично-рівневого обмеження не виводяться у списку Workspaces сторінки з'єднання (керування таблицями ведеться у workspace editor).

Data Permissions — Редагування

Спрощення SQL-рівнів у UI

Хранилище зберігає рідну 5-рівневу модель (select | insert | update | delete | execute), але адміністративний інтерфейс групує їх у три зрозумілі ярлики:

UI-ярлик	Базові SQL-рівні
View	select
Edit	insert ☐ update ☐ execute (перемикаються разом)
Delete	delete

MCP-проксі робить перевірку через `set-membership (connector.permissions.has(required))` — для нього insert/update/execute функціонально однакові, тому об'єднання їх в один Edit-бакет нічого не ламає. При збереженні з UI обирається канонічний представник (update для Edit). Хелпери

— `effectiveLevelsFor()`, `expandEffectiveSet()` у `app/(dashboard)/permissions/permissions-types.ts`.

Workspace Editor (`/workspaces/[id]`)

Робочий простір — основний механізм надання доступу великим групам користувачів. У редакторі:

- **Details:** ім'я, опис.
- **Data Sources:** вибір з'єднань, прикріплених до робочого простору; для кожного — опційний `allowedTables` (список дозволених таблиць; `null` = усі).
- **Users:** список членів робочого простору з трьома чекбоксами `per-member` (`View / Edit / Delete`). Ці права застосовуються до всіх з'єднань робочого простору однаково, оскільки `WorkspaceUser.permissions` — це `per-membership`, не `per-connector`.

Direct Grants (Permissions Matrix → By User)

Інлайн-редагування прямих грантів виконується прямо в матриці. У ряді кожного з'єднання — три pill-кнопки (`View / Edit / Delete`), які:

- **Активні** (`primary tint`) — якщо є прямий грант на цей рівень.
- **Зелені** — якщо рівень доступний через робочий простір (`read-only` показ; клік додає прямий грант).
- **Підсвічені** — якщо рівень походить лише з `workspace` і доступне редагування через діалог.

`Workspace`-походження клітинки показується як клікабельний чіп. Клік відкриває діалог «`Edit X workspace permissions for Y`» з амбер-попередженням, що зміна вплине на усі з'єднання робочого простору. Той самий діалог можна відкрити, клікнувши на затьмарену `SQL-pill` — корисно, коли користувач має лише `workspace`-доступ і хоче змінити перміс на одному кроці.

Bulk операції

Виділення 2+ користувачів (або 2+ з'єднань) у списку відкриває `BulkBar` на правій панелі.

Адміністратор обирає одного контрагента (з'єднання — для `bulk`-користувачів, або користувача — для `bulk`-з'єднань), три рівні (`View / Edit / Delete`) і натискає `Grant direct access` (масовий `PUT`) або `Revoke direct grants` (масовий `DELETE`). `Bulk` торкається лише прямих грантів — `workspace`-членства не змінюються.

Table-Level Allowlist та Blocklist

У відмінність від реляційних БД, де можна задавати WHERE-умови, MCP Gateway працює на рівні MCP-tools. Обмеження доступу здійснюється трьома рівнями:

1. `DataSource.blockedTables` — постійний deny-list на рівні з'єднання. Будь-який tool call, що націлений на таблицю з цього списку, відхиляється — незалежно від workspace/direct гранту. Редагується через кнопку Block tables на сторінці з'єднання. Це «вічно заборонені таблиці» власника з'єднання.
2. Workspace-level allowedTables (`WorkspaceDataSource.allowedTables`) — обмеження для всіх членів робочого простору на конкретному з'єднанні. `null` = усі таблиці; `ne-null` = лише перелічені.
3. Direct-grant allowedTables (`UserDataSourceAccess.allowedTables`) — обмеження для конкретного користувача на прямий грант. Та сама семантика.

Алгоритм застосування

- На `tools/list`: якщо для з'єднання задано `allowedTables`, видаляються «raw query» tools (інструменти типу `query`, `run_sql`, `execute_ddl`), оскільки SQL-сирий запит не можна обмежити таблично.
- На `tools/call`: аргументи tool-виклику скануються на ключі `table_name`, `table`, `module`, `object_name`, `objectName`, `resource`. Якщо знайдено таблицю поза `allowedTables` або в `blockedTables` — виклик відхиляється до того, як буде звернення до апстріму (`PERMISSION_DENIED`).
- Пост-фільтр відповіді: відповіді на `list-tools` (наприклад, `list_tables`) проганяються через `filterListedTablesText()`, який випуває згадки заборонених таблиць.

Row-Level Security не реалізовано на боці шлюзу. Якщо потрібно фільтрувати рядки за умовою (наприклад, `REGION = 'EU'`), це покладається на upstream MCP-сервер.

Workspace Permissions

Робочий простір — основний механізм групування користувачів та з'єднань. Кожен член отримує одні й ті ж SQL-рівні (View / Edit / Delete) на всі з'єднання робочого простору. Workspaces дозволяють делегувати адміністрування секцією організації.

Сторінка /workspaces

Список робочих просторів. Глобальний адміністратор бачить усі workspaces; адміністратор, обмежений scope (через `UserRole.workspaceId`), бачить лише ті, до яких має доступ.

Workspace-scoped адміністратори

`UserRole`-рядок з ненульовим `workspaceId` дає правам ролі застосовуватися лише в межах конкретного робочого простору. Наприклад:

- Alice має `workspace_admin` з `workspaceId` = «sales» — вона може керувати членами та правами в «Sales», але не в «Engineering».
- Bob має `admin` без scope — глобальний адміністратор.

Резолвер `canInWorkspace(userId, key, wsId)` коректно обробляє обидва випадки.

Workspace MCP URL

Кожен робочий простір має власний `mcpUid` — випадковий 24-байтовий `base64url`-рядок. URL виду `https://gateway/api/mcp/w/{mcpUid}` подає лише дані цього робочого простору для `members`, які

пройшли OAuth. Прямі гранти не входять у workspace-scoped доступ — це навмисно, щоб робочий простір залишався чистим scope-обмеженим джерелом.

Окрім workspace-scoped URL, є /api/mcp (generic) — один URL для всіх користувачів, який віддає об'єднання всіх workspace-членств і прямих грантів. OAuth-обліковий запис є authoritative — uid у URL більше не використовується.

Per-Member Permission Inline Edit

На сторінці /permissions (вкладки By User та By Connection) workspace-source чіпи клікабельні. Клік відкриває діалог редагування рівнів членства з амбер-попередженням, що зміна вплине на усі з'єднання робочого простору. PUT-запит йде на /api/workspaces/{id}/users/{userId} (gated на workspaces.manage_data_permissions). Збереження порожнього списку рівнів видаляє членство повністю (WORKSPACE_USER_REMOVED audit event).

Кінець документа. Для технічних деталей реалізації див. SPECIFICATIONS.md та коментарі у lib/permissions/, lib/auth.ts, app/api/mcp/.